GMI German-Malaysian Institute

DIPLOMA PROGRAMME

ASSIGNMENT

Academic Period: January 2026

Program	:	**CYBER SECURITY TECHNOLOGY (CBS)**
Course	:	**PENETRATION TESTING**
Code	:	**CBS 2353**
Duration	:	**2 WEEKS**
Total Marks	:	**100 (15%)**

Title	:	**SECURITY TRENDS** **(Bug Bounty Programs and Ethical Hacking)**

Student's Name	:	1. **Abdul Hariz Mohd b. Sarnudin (CBS24070208)**
(Individual / Group)		2. **Muhammad Danial b. Norhisam (CBS24070222)**
TTO's Name	:	**Ts. Noormelah Binti Shamsul Anuar**
Semester/Trade/Group	:	**3/DCBS/1**
Date	:	**20 January 2025**

Assessment Specification Table (CBS)

Assignment

Raw Marks:	100
Percentage (in Doc 01):	15

No	Assessment Criteria	Full Marks	Score (if applicable)	Student's Marks	CLO	Level of Difficulty	DK, DP, NA (ETAC Programme Only)	Comments	PLO GMI: PLO CBS 9 PLO - Start Intake July 2023	PLO GMI: PLO MBOT 9 PLO
1	Content and format of report	20			1	2			1	1
2	Identification of Main Issues	20			1	2			1	1
3	Knowledge of Findings	20			1	3			1	1
4	Fluency & Clarity	20			1	3			1	1
5	Defence ability	20			1	3			1	1
									#N/A	#N/A
									#N/A	#N/A
									#N/A	#N/A
									#N/A	#N/A
	Total Full Marks	**100**		**Total Student's Marks**						

SUMMARY

Note:
FM - Full Marks,
StM - Student's Mark

	CLO	Raw Marks FM	Raw Marks StM	Percentage FM	Percentage StM	PLO GMI: PLO CBS 9 PLO - Start Intake July 2023 PLO	Raw Marks FM	Raw Marks StM	Percentage FM	Percentage StM	PLO GMI: PLO MBOT 9 PLO PLO	Raw Marks FM	Raw Marks StM	Percentage FM	Percentage StM
Total	CLO 1	100		15.0		PLO 1	100		15.0		PLO 1	100		15.0	
	CLO 2	0		0.0		PLO 2	0		0.0		PLO 2	0		0.0	
	CLO 3	0		0.0		PLO 8	0		0.0		PLO 8	0		0.0	
	CLO 4	0		0.0		#N/A	0		0.0		#N/A	0		0.0	
	CLO 5	0		0.0		#N/A	0		0.0		#N/A	0		0.0	
	CLO 6	0		0.0		#N/A	0		0.0		#N/A	0		0.0	
	Total Marks	**100**		**15.0**											
	Signature	( )													

NO.	CRITERIA	APPROACHES EXPECTATIONS [1]	MEETS EXPECTATIONS [2]	EXCELLENT [3]	MARKS ALLOCATED	WEIGHTED MARKS OBTAINED	MARKS
	GROUP COMPONENT (TOTAL MARK = 40%)						
1	**Content and format of report**	The content was minimally relevant and formatting accordingly	The content was generally relevant to the given task and formatting accordingly	The content was very relevant to the given task and formatting accordingly	20%	M/3 x 20%	
2.	**Identification of Main Issues – quality & relevant**	Unable to identify and understand the issues of the topic	Able to identify and understand some of the issues of the topic	Able to identify and understand all the main issues of the topic	20%	M/3 x 20%	
	INDIVIDUAL COMPONENT (TOTAL MARK = 60%)						
3	**Knowledge on the topic -clear explanation using correct term**	Students demonstrate some knowledge of the topic	Student demonstrates sufficient level of the topic	Student demonstrates well verse of the topic	20%	M/3 x 20%	
4	**Fluency and Clarity (presentation)**	Student is not fluent and voice are not clear.	Student is fluent and voices are slightly easy to be heard clearly.	Student is very fluent, and voices are easy to be heard clearly.	20%	M/3 x 20%	
5	**Defence ability/ presentation (Q&A)**	Not able to answer questions, not prepared and no confidence at all	Able to answer questions but with little preparation and confidence	Able to all answer questions very well and confidently. Very well prepared	20%	M/3 x 20%	
				TOTAL	100%		

EVALUATION CRITERIA	INDIVIDUAL COMPONENT (TOTAL MARK = 60)	
	STUDENT 1	**STUDENT 2**
Knowledge on the topic		
Fluency and Clarity (presentation)		
Defense ability/presentation (Q&A)		

STUDENT'S NAME	INDIVIDUAL MARK (60 MARKS)	GROUP MARK (40 MARKS)	TOTAL MARK
STUDENT 1: Abdul Hariz Mohd b. Sarnudin (CBS24070208)			
STUDENT 2: Muhammad Danial b. Norhisam (CBS24070222)			

Instruction:

Pick a topic that you would like to learn about in depth. The topic will be given by your TTO.

Each group must answer **ALL** of the following in their presentation:

1. What is the security issue or trend?
2. Why is it considered a **current or emerging** problem?
3. How does the attack or risk work (simple explanation)?
4. Who is affected (individuals, companies, governments)?
5. What are **real-world examples or recent cases**?
6. What basic security controls or solutions can reduce the risk?

Content of presentation & slide:

1) Introduction to the topic
2) How the threat or trend works
3) Recent example or case study
4) Impact on users or organizations
5) Prevention or mitigation methods
6) Conclusion
7) References

Submission:
Slide (in pdf format)
Report (in pdf format)

Grading:
1) Report
2) Presentations

Report & Slide:
1) Maximum of 10 pages of report
2) Maximum of 10 slides

Project Presentations:
Each individual /team has 10 minutes' presentations+ 5 minutes Q&A

Group:
2 or 3 students per group / individual

Table of Contents

Introduction..... 7

Explanation..... 8

Real-world example..... 9

Impact on Organization..... 11

Prevention and mitigation methods..... 12

Conclusions..... 14

References..... 15

Introduction

Bug bounty programs and ethical hacking are part of a new and emerging trend in cybersecurity where organizations work with individuals to identify weaknesses in their systems and address them before they are exploited by hackers. Ethical hacking, also known as white-hat hacking, refers to the practice of simulating cyberattacks on computer systems or networks with permission to identify weaknesses. Bug bounty programs are essentially a reward system where individuals or teams of hackers are rewarded for identifying weaknesses in computer systems or networks. This new trend in cybersecurity helps to address the growing complexity of cyber threats by tapping into the expertise of thousands of hackers globally.

The new and emerging trend in cybersecurity is considered current and emerging due to the growing complexity of cyber threats. With data breaches costing companies an average of millions of dollars each year, it is clear that traditional cybersecurity measures are not sufficient to address all aspects of cybersecurity. Bug bounty programs have thousands of hackers globally and are thus considered a new and emerging trend in cybersecurity.

Explanation

Bug Bounty & Ethical Hacking 101

Ethical hacking is the broad practice where authorized security experts intentionally attempt to break into computer systems to find weaknesses before malicious criminals do. These professionals use the same tools and techniques as real attackers, but they operate with permission and the goal of fixing security flaws rather than exploiting them for harm. Companies hire ethical hackers to proactively test their defenses, ensuring that customer data and internal networks are safe from cyber threats.

A bug bounty program is a specific type of ethical hacking initiative where organizations crowdsource their security by inviting the public to find and report vulnerabilities in exchange for a monetary reward. Instead of hiring a single team to test their software, a company publishes a set of rules and offers cash payments to any researcher who can successfully demonstrate a valid security flaw. This model allows businesses to leverage the diverse skills of thousands of independent hackers simultaneously, paying only for the valid results they receive.

While ethical hacking often involves a contracted team performing a scheduled test, bug bounty programs run continuously and rely on a global community of freelance researchers. This difference means that traditional ethical hacking provides a structured, comprehensive assessment of a specific system, whereas bug bounties offer a constant, wide-ranging search for bugs by incentivizing the competitive nature of the hacking community.

Real-world example

Apple's Security Bounty Program

One of the biggest and most prestigious bounty programs is run by Apple. It was initially small, starting in 2016 with only a handful of invited participants. However, it was opened to everyone in 2020. Apple pays ethical hackers who identify significant security vulnerabilities on iPhones, iPads, Mac computers, Apple Watches, Apple TVs, Vision Pros, iCloud, and other Apple devices. Apple has already paid over 800 researchers over $35 million for their efforts in making Apple devices more secure by the beginning of 2026. This is important because Apple has over 2.35 billion active devices worldwide, and it is a massive job to keep all of these devices secure.

Apple made it much stronger in October 2025 to help fight against high-end spyware attacks. They increased the reward amount to $2 million for very dangerous exploits. Exploit chains refer to a series of bugs that enable someone to gain full control of a device without any action on the user's part. They also offered large bonuses of up to +150% if the bug works even if a special "Lockdown Mode" is enabled or if it exists in beta software. In some cases, these high-end reward amounts can exceed $5 million. Apple also came up with something called Target Flags. These are special checks that are built into devices to help researchers quickly and easily prove that a bug exists so that they can get their reward faster. Below is tabulation of reward taken directly from the apple website.

	Current Maximum	New Maximum
Zero-click chain: Remote attack with no user-interaction	$1M	$2M
One-click chain: Remote attack with one-click user-interaction	$250K	$1M
Wireless proximity attack: Attack requiring physical proximity to device	$250K	$1M
Physical device access: Attack requiring physical access to locked device	$250K	$500K
App sandbox escape: Attack from app sandbox to SPTM bypass	$150K	$500K

Figure 1: Rewards for complete exploit chains

These updates were implemented because actual spyware attacks have become very costly and sophisticated, with prices reaching millions of dollars to develop. Apple wants the best hackers to submit their findings to them rather than selling them to malicious individuals. So far, this program has helped resolve many severe problems, such as issues in the web browser (WebKit), privacy settings, and even methods for attackers to access iCloud data. Although Apple keeps the most severe vulnerabilities hidden until they are patched, it is no secret that this program has already prevented many potential attacks.

Notable Discoveries

While many high-severity reports remain confidential until patches are deployed, the program has driven numerous fixes over the years. A well-documented case that is frequently referenced as foundational involved researcher Sam Curry and his team identifying **55 vulnerabilities** across Apple services over three months, including **11 critical issues**. These ranged from remote code execution via authorization bypasses and command injection to wormable iCloud flaws that could propagate via email and steal photos, videos, documents, and more from victims and their contacts. Another allowed brute-force access to an Apple Distinguished Educator admin account, potentially enabling internal network penetration. Apple addressed these rapidly and paid the team a substantial bounty

More recent examples include:

- Various WebKit-related sandbox escapes and TCC (Transparency, Consent, and Control) bypasses on macOS, which have informed hardening of privacy protections.
- A 2025 Stored XSS vulnerability on developer.apple.com and related domains (reported by researcher Youssef Desouki / Zombie Hack), allowing arbitrary JavaScript execution across sensitive Apple web assets. This earned a $5,000 bounty after validation, triage, and remediation.

In conclusion, Apple’s Security Bounty program demonstrates that a giant corporation can collaborate with the international hacking community to outsmart cyber thieves. The massive 2025 changes have raised the bar for bug bounties, making ethical hacking more lucrative and helping to safeguard billions of people every day.

Impact on Organization

For the organization, implementing ethical hacking and bug bounty programs fundamentally shifts the security posture from reactive to proactive, drastically reducing the risk of catastrophic financial losses and legal liabilities associated with data breaches. By identifying and patching vulnerabilities before malicious actors can exploit them, companies safeguard their intellectual property and ensure unbroken operational continuity, which is critical for maintaining a competitive edge. Furthermore, a visible commitment to rigorous, continuous security testing enhances brand reputation, fostering deep investor confidence and distinguishing the business as a trustworthy leader in a market often plagued by security failures.

For the user, these security measures translate directly into the assurance that their sensitive personal information, such as financial records, passwords, and private data, remains shielded from theft and exploitation. Users benefit from a more reliable and stable digital experience, as proactive testing prevents the service outages and system crashes that frequently result from ransomware or DDoS attacks. Ultimately, the behind-the-scenes work of ethical hackers allows users to interact with digital products with complete peace of mind, knowing that the platforms they rely on daily are actively fortified against cyber threats.

Prevention and mitigation methods

In order to successfully execute a bug bounty program, the following best practices should be followed:

1. **Define Clear Scope and Rules**

Create a thorough, publicly accessible policy that clearly outlines the permitted vulnerability types, in-scope assets, and clearly out-of-scope activities. Include a strong safe harbor provision that offers legal protection to researchers who follow the program's rules. This will promote responsible disclosure and lessen the possibility that participation will be discouraged by legal issues.

2. **Assign a Dedicated Team**

Assign a specialized team to handle submission triaging, consisting of a program manager and certified security analysts. With a goal response time of no more than 48 hours, this team should guarantee prompt acknowledgment and evaluation of reports. Prompt and professional communication fosters researcher confidence and enhances the program’s reputation within the security community.

3. **Offer Competitive Bounties**

Release a transparent, tiered reward table that is benchmarked against industry norms and corresponds with vulnerability severity levels. Disburse payments promptly upon validation and confirmation of the vulnerability rather than after remediation, thereby building trust and encouraging continued high-quality submissions. Supplementary bonuses for particularly innovative or high-impact findings can further attract skilled researchers.

4. **Promote Quality Reports**

Demand thorough submissions that include repeatable procedures, proof-of-concept (PoC) code when appropriate, supporting documentation such as screenshots or logs, and a concise description of the possible impact on business or security. Regardless of whether a report is accepted or rejected, offer helpful criticism to promote researcher growth and raise the standard of all upcoming submissions.

5. **Integrate with Existing Security Processes**:

Align the bug bounty program with internal security initiatives like red team exercises, vulnerability management, and penetration testing. Review and update program policies, scope, and reward levels on a regular basis (at least once a year) to take organizational priorities, lessons learned from submitted reports, and evolving threats into account.

6. **Utilize Bounty Platforms**

Utilize reputable third-party platforms such as HackerOne, Bugcrowd, or Intigriti to manage program operations efficiently. These platforms offer streamlined submission workflows, automated triage tracking, secure payment processing, pre-vetted researcher communities, and standardized templates for scope and safe harbor policies, thereby reducing administrative overhead and enhancing program credibility and reach.

These techniques help to reduce false positives by concentrating on high-impact vulnerabilities.

Conclusions

Ethical hacking has evolved from a niche precaution into the foundational backbone of modern digital trust, shifting cybersecurity from a reactive panic to a proactive discipline. By harnessing the same creativity and tools as malicious attackers, organizations can dismantle vulnerabilities before they ever become liabilities, effectively turning their greatest potential weakness into a source of resilience. Platforms like Cobalt have accelerated this transformation by democratizing access to elite talent, proving that security is no longer just about building higher walls but about testing those walls continuously and transparently. As the industry moves toward a hybrid future of human expertise and AI-driven speed, the ability to integrate offensive testing directly into the development lifecycle will define which companies survive the next generation of cyber threats. Ultimately, the true value of ethical hacking lies not just in finding bugs, but in giving businesses the confidence to innovate without fear.

References

Apple Inc. (2025, October 10). *A major evolution of Apple Security Bounty, with the industry's top awards for the most advanced research*. Apple Security Research. https://security.apple.com/blog/apple-security-bounty-evolved

Bug Bounty Programs – HackerOne
HackerOne. (n.d.). *Bug bounty programs*. https://www.hackerone.com/bug-bounty-programs

What is Bug Bounty? – Wiz
Wiz. (n.d.). *What is bug bounty?* https://www.wiz.io/bug-bounty-masterclass/foundations/what-is-bug-bounty

Bug Bounty Programs and Ethical Hacking – Cybersecurity Center of Excellence
Schmitt, N. (2025, September 9). *Bug bounty programs and ethical hacking*. Cybersecurity Center of Excellence. https://coecyber.io/bug-bounty-programs-and-ethical-hacking

Slashdot. (n.d.). *Astra Pentest vs BreachLock vs Cobalt Pentest vs Hakware Archangel* [Software comparison]. Retrieved February 3, 2026, from https://slashdot.org/software/comparison/Astra-Pentest-vs-BreachLock-vs-Cobalt-Pentest-vs-Hakware-Archangel/

Mohan, M., & Thomas, A. (2025, October 29). *Cobalt pricing 2025: Is it worth the investment?* Beagle Security. https://beaglesecurity.com/blog/article/cobalt-pricing.html

Scarfone, K., Souppaya, M., Cody, A., & Orebaugh, A. (2008). *Technical guide to information security testing and assessment* (NIST Special Publication 800-115). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-115

Cobalt. (2025). *The state of pentesting report 2025*. https://resource.cobalt.io/state-of-pentesting-2025